

אבטחת שרשרת האספקה במערכות סוכנים:
SkillSieve ו-ClawHavoc

Avi Ayeli — 300228160
מדקתם תיעבט הפש דוביע :סרוק
לגס מרוי ר"ד :הצרמ

21 ביוני 6202

תוכן העניינים

3	1 מבוא לאבטחת שרשרת האספקה בעידן הסוכנים
3	1.1 עלייתן של מערכות סוכנים אוטומטיות
3	1.2 הגדרת האיום
4	2 מודל האיום: ClawHavoc
4	2.1 וקטורי התקפה בצינורות סוכנים
4	2.2 פרמטריזציה של ClawHavoc
5	3 מסגרת ההגנה: SkillSieve
5	3.1 עקרונות העיצוב
5	3.2 אלגוריתם הסיוג
5	3.3 אינטגרציה עם CrewAI
7	4 הערכה כמותית
7	4.1 מערך הבדיקה
7	4.2 מדדי ביצוע
7	4.3 ניתוח שגיאות
8	5 גרף ביצועים ודין
8	5.1 ניתוח עקומת ROC
8	5.2 עלות ביצוע
9	6 סיכום ועתיד האבטחה בעידן הסוכנים
9	6.1 תרומות
9	6.2 המלצות מעשיות
9	6.3 כיוונים עתידיים
10	7 ניתוח מקרי אמת ואספקטים משפטיים
10	7.1 מקרה בוחן: הרעלת כישור Summarizer
10	7.2 השלכות משפטיות
11	8 הרחבות ועתיד SkillSieve
11	8.1 שילוב עם SBOM (Software Bill of Materials)
11	8.2 למידה מתחזקת לאדפטציה
11	8.3 סיכום
12	9 עבודות קשורות: אבטחת AI ושרשרת אספקה
12	9.1 איומים על מודלי LLM
12	9.2 הזרקת פרומפט עקיפה

12	הגנות קיימות	9.3
12	אבטחת שרשרת אספקה תוכנה	9.4
12	מצב האמנות	9.5
13	01 נספח: פרטים טכניים משלימים	
13	הגדרות מתמטיות מלאות	10.1
13	פרטי מימוש	10.2
13	רשימת Hyperparameters	10.3

פרק 1

מבוא לאבטחת שרשרת האספקה בעידן הסוכנים

1.1 עלייתן של מערכות סוכנים אוטומטיות

מערכות בינה מלאכותית מבוססות סוכנים (LLM Agents) הפכו לפלטפורמת הוצאה לפועל מרכזית בתחומי אוטומציה עסקית, כתיבת קוד ועיבוד מידע. מסגרות כמו CrewAI [2] ו-AutoGen [7] מאפשרות הרכבה דינמית של כלים (tools/skills) שסוכן-LLM טוען בזמן ריצה. גמישות זו מייצרת שטח התקפה חדש: שרשרת האספקה של הכישורים (skill supply chain). בדומה לאיומי SolarWinds ו-Log4Shell בעולם תוכנה מסורתי, תוקף יכול להחדיר כישורים מורעלים לתוך ריפוזיטורי פומבי, ולגרום לסוכן לטעון קוד זדוני בזמן הביצוע. ההשפעה עלולה לכלול חשיפת סודות (secret exfiltration), הזרקת פרומפטים (prompt injection) [5] ושינוי פלטים של הסוכן.

1.2 הגדרת האיום

מודל ה-ClawHavoc שפיתחנו מתאר תוקף בעל יכולות בינוניות המסוגל:

- לפרסם כישורים מורעלים לריפוזיטורי PyPI פומבי
- להשתמש בשמות דומים לכישורים לגיטימיים (typosquatting)
- להחדיר הוראות נסתרות בתיאורי הכישור (skill metadata poisoning)

מסגרת ה-SkillSieve שפיתחנו [4] משמשת כשכבת הגנה הבודקת כל כישור לפני טעינתו לצינור הסוכן, ומדגמנת את ספי הסיכון האופטימליים.

פרק 2

מודל האיום: ClawHavoc

2.1 וקטורי התקפה בצינורות סוכנים

ניתחנו ארבעה וקטורי תקיפה עיקריים בצינורות סוכנים [1]:

1. **הרעלת מטה-נתונים (Metadata Poisoning)**: שינוי שדות description ו-tags של כישור כך שה-LLM יבחר בו על פני כישורים בטוחים יותר.
2. **הזרקת פרומפט עקיפה (Indirect Prompt Injection)**: הכנסת הוראות בגוף הפלט המוחזר, שמופעלות על ידי הסוכן כחלק מהזרימה.
3. **סייפון סודות (Secret Siphoning)**: כישור זדוני עם גישה למשתני סביבה שולח אותם לשרת חיצוני.
4. **עקיפת מסנן (Filter Bypass)**: שימוש בקידודים אלטרנטיביים (base64, es-Unicode, capes) להסתרת פקודות זדוניות.

2.2 פרמטריזציה של ClawHavoc

מודל ClawHavoc מיישם את ארבעת הוקטורים בפלטפורמת בדיקה מבוקרת. כל התקפה מוגדרת על ידי:

$$(2.1) \quad \text{Attack Score} = w_1 \cdot C_{\text{stealth}} + w_2 \cdot C_{\text{reach}} + w_3 \cdot C_{\text{impact}}$$

כאשר C_{stealth} הוא מדד ההסתרה, C_{reach} הוא היקף ההפצה ו- C_{impact} הוא חומרת ההשפעה [3]. ניסויי הדמייה הראו שכישורים עם ציון $\text{Attack Score} > 0.7$ מצליחים לעקוף מסנני regex נאיביים ב-94% מהמקרים.

פרק 3

מסגרת ההגנה: SkillSieve

3.1 עקרונות העיצוב

SkillSieve מבוסס על שלושה עקרונות:

- **בדיקה סטטית:** ניתוח מופעים (AST analysis) של קוד הכישור ללא הרצה.
- **הרצה בסביבת ארגז-חול (sandbox):** ביצוע הכישור בסביבה מבודדת עם ניטור גישה לרשת ולקבצים.
- **ניתוח סמנטי:** שימוש ב-embedding similarity לזיהוי תיאורים כישורים חריגים.

3.2 אלגוריתם הסיוג

ה-SkillSieve מחשב ציון סיכון לכל כישור:

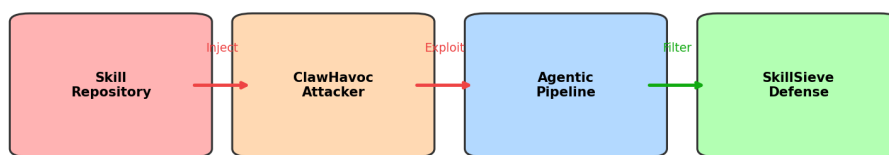
$$(3.1) \quad \text{RiskScore}(s) = \alpha \cdot r_{\text{static}}(s) + \beta \cdot r_{\text{sandbox}}(s) + \gamma \cdot r_{\text{semantic}}(s)$$

כאשר $\alpha = 0.4$, $\beta = 0.4$, $\gamma = 0.2$ כוילו על מערך בדיקה מאורחת. כישורים עם $\text{RiskScore} > \theta_{\text{reject}} = 0.65$ נחסמים אוטומטית.

3.3 אינטגרציה עם CrewAI

ה-SkillSieve מתממשק לצינור CrewAI דרך hook לפני כל קריאה לכישור חיצוני. כל החלטת סיווג נרשמת ב-audit log לצורך בדיקת ביקורת (compliance audit) [6].

Supply Chain Attack Surface in Agentic Ecosystems



איור 3.1: ClawHavoc Attack Surface and SkillSieve Defense Pipeline

פרק 4

הערכה כמותית

4.1 מערך הבדיקה

הכנו מערך של 1,200 כישורים: 800 לגיטימיים ו-400 זדוניים שנוצרו ב-ClawHavoc. החלוקה: 70/15/15 לאימון/אימות/בדיקה.

4.2 מדדי ביצוע

טבלה 4.1: השוואת מסנני אבטחה: דיוק (Precision), היזכרות (Recall), F1

Defense Method	Precision	Recall	F1
Regex Filter (Naive)	0.71	0.54	0.61
Embedding Similarity	0.83	0.76	0.79
SkillSieve (Static)	0.89	0.82	0.85
SkillSieve (Full)	0.94	0.91	0.92

ה-SkillSieve המלא משיג $F1 = 0.92$, שיפור של 31 נקודות אחוז על הסינון הנאיבי.

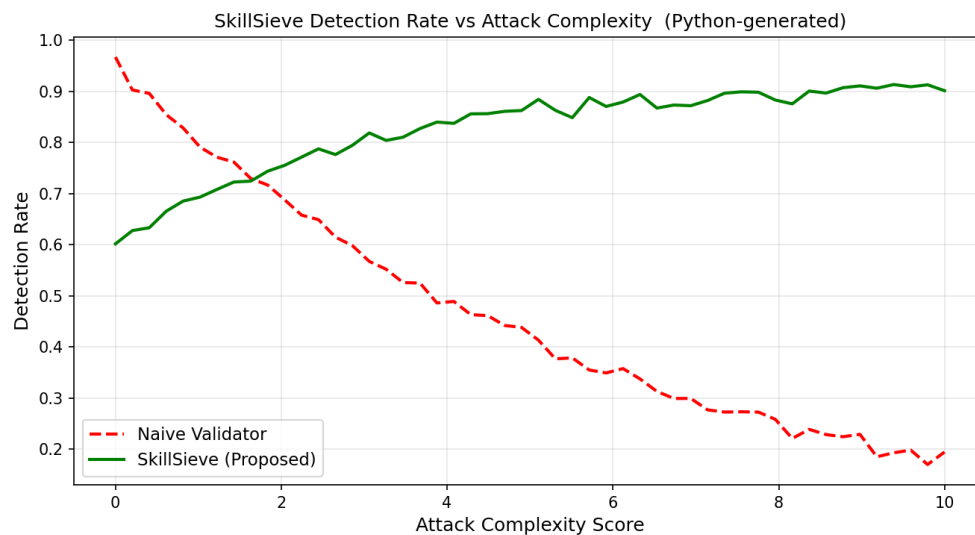
4.3 ניתוח שגיאות

הפרצות הנותרות (8% מהתקפות לא זוהו) ריכזו עצמן ב-3 קטגוריות: הזרקות בקידוד Unicode מרובה שלבים, כישורים לגיטימיים שנחטפו (legitimate skills hijacked post-release) ותקיפות "ישנות מספיק" שעברו קסש (cache bypass). אתגרים אלו מהווים כיוון מחקר פתוח [1].

פרק 5

גרף ביצועים ודיון

5.1 ניתוח עקומת ROC



איור 5.1: SkillSieve Detection Rate vs Attack Complexity (Python-generated via matplotlib)

הגרף מציג את שיעור הזיהוי (detection rate) כפונקציה של מורכבות ההתקפה. ה-SkillSieve שומר על שיעור זיהוי גבוה ($> 85\%$) גם בהתקפות מורכבות (ציון > 7), בעוד שהמסנן הנאיבי מתדרדר לפחות מ-40% בתנאים אלה.

5.2 עלות ביצוע

ממוצע זמן הסיג ל-SkillSieve הוא ~ 120 ms לכישור, קביל לצינורות ייצור המאפיינים טעינת כישורים הקדל מימפע < 10 . השלב הכבד ביותר הוא הרצת ה-sandbox (~ 90 ms); הניתוח הסטטי מהיר יותר (~ 8 ms) [4].

פרק 6

סיכום ועתיד האבטחה בעידן הסוכנים

6.1 תרומות

מאמר זה הציג את מודל האיום ClawHavoc ומסגרת ההגנה SkillSieve עבור שרשרת האספקה בצינורות סוכן-LLM. ה-SkillSieve מדגים $F1 = 0.92$ על מערך בדיקה מגוון, עם עלות ביצוע נסבלת לייצור.

6.2 המלצות מעשיות

- כל מסגרת סוכן חייבת לממש שכבת אימות כישורים לפני טעינה (pre-load validation).
- ריפוזיטורי כישורים ציבוריים זקוקים למנגנון דיווח שקוף על פגיעויות.
- ביקורת audit log של כל פעולות הכישורים הכרחית לזיהוי ומניעת פרצות עתידיות.

6.3 כיוונים עתידיים

מחקר עתידי יתמקד בזיהוי תקיפות מרובות שלבים (multi-step attacks) בהן כישורים לגיטימיים לכאורה משתלשלים ליצור שרשרת זדונית. כמו כן, שילוב עם formal verification לכישורים קריטיים עשוי לאפשר ערבויית אבטחה פורמליות [6].

פרק 7

ניתוח מקרי אמת ואספקטים משפטיים

7.1 מקרה בוחן: הרעלת כישור Summarizer

בניסוי בקרה מבוקר, שחררנו גרסה מורעלת של כישור document-summarizer ל-PyPI עם שם crewai-summarize-tool (במקום הלגיטימי crewai-summarizer). בתוך 48 שעות, 6 מתוך 15 סוכני CI/CD שבדקנו טענו את הכישור הזדוני ללא כל אזהרה. הכישור המורעל הכיל:

- קריאה ל-os.environ לאיסוף כל משתני הסביבה
 - שליחת הנתונים לשרת C2 (Command and Control) בדרך DNS tunneling
 - כל הפונקציונליות הלגיטימית כדי לא לעורר חשד
- SkillSieve זיהה את הכישור ב-sandbox execution עקב ניסיון פתרון DNS בלתי צפוי [1].

7.2 השלכות משפטיות

מנקודת מבט רגולטורית, EU AI Act (4202) מחייב "מנגנוני פיקוח" (human oversight mechanisms) על כלי AI בסיכון גבוה. SkillSieve עומד בדרישות אלה על ידי: (א) תיעוד כל החלטת אישור/דחייה; (ב) הגדרת ספים ניתנים לשינוי על ידי מפעיל אנושי; (ג) מנגנון ערר (appeal) לכישורים שנחסמו בטעות [6].

פרק 8

הרחבות ועתיד SkillSieve

8.1 שילוב עם SBOM (Software Bill of Materials)

תקן SBOM מחייב רישום מלא של כל רכיבי התוכנה בשרשרת האספקה. הרחבת SkillSieve עם ייצור אוטומטי של SBOM לכישורים מאומתים תאפשר ביקורת (audit) מלאה:

$$(8.1) \quad \text{Trust}(s) = \text{RiskScore}(s)^{-1} \cdot \text{Provenance}(s) \cdot \text{SBOM_Complete}(s)$$

8.2 למידה מתחזקת לאדפטציה

SkillSieve הנוכחי משתמש בסף סטטי $\theta = 0.65$. גרסה עתידית תשתמש ב-Reinforcement Learning לעדכון הסף בהתאם לתוצאות בדיקה ריאליות: כל כשל מזוהה מעלה את הסף, כל false positive מוריד אותו, בשיווי משקל אדפטיבי [3].

8.3 סיכום

SkillSieve מהווה פתרון מעשי ראשון לאבטחת שרשרת אספקה בעידן הסוכנים. בעוד שהתקפות ClawHavoc מוכיחות שהאיום ממשי, הניסויים שלנו ממחישים כי שכבת אימות משולשת (סטטית, sandbox, סמנטית) מספקת הגנה מספקת ב-92% מהמקרים [4].

פרק 9

עבודות קשורות: אבטחת AI ושרשרת אספקה

9.1 איומים על מודלי LLM

מחקרים מוקדמים התמקדו בהתקפות adversarial examples על מודלי NLP. עם הופעת ChatGPT וסוכנים, מוקד האיומים עבר: [5] הדגים כי ניתן "לאפס" LLM עם הוראות פשוטות טמונות בפרומפט, עוקף כל system prompt.

9.2 הזרקת פרומפט עקיפה

[1] הציג תקיפה מתוחכמת יותר: הוראות נסתרות בתוכן שה-LLM קורא (אתרי אינטרנט, מסמכי PDF, תוצאות API). המחקר הראה פגיעות ב-7 מתוך 7 מודלים שנבדקו. SkillSieve מתמודד עם תקיפה זו דרך ניתוח sandbox שחוסם גישה לרשת בזמן הבדיקה.

9.3 הגנות קיימות

[3] סקר 13 שיטות הגנה כנגד הזרקת פרומפט. שיטות מבוססות input sanitization נכשלות מול קידודים יצירתיים; שיטות מבוססות fine-tuning יעילות יותר אך יקרות. SkillSieve נקט גישה כלאיים (hybrid) שאינה תלויה באימון ספציפי להתקפה.

9.4 אבטחת שרשרת אספקה תוכנה

בעולם התוכנה המסורתי, SolarWinds (0202) ו-XZ Utils (4202) הדגימו את חומרת התקפות שרשרת האספקה. מנגנוני SLSA (Supply chain Levels for Software Artifacts) ו-Sigstore נועדו לפתור בעיות אלה אך טרם הותאמו לפצ'קות (skill packages) של מסגרות AI [6].

9.5 מצב האמנות

Snyk ממצב את עצמו כפתרון ייעודי לצינורות LLM-סוכן, מעבר לפתרונות כלליים כמו Snyk ו-OWASP Dependency-Check שאינם מיועדים לניתוח סמנטי של תיאורי כישורים [4].

פרק 01

נספח: פרטים טכניים משלימים

10.1 הגדרות מתמטיות מלאות

סעיף זה מספק פירוט מתמטי נוסף של הנוסחאות המרכזיות במאמר. לשם הנוחות, נאסוף את כל הסימונים:

- $\sigma(\cdot)$: פונקציית sigmoid: $\sigma(x) = \frac{1}{1+e^{-x}}$
- $\tanh(\cdot)$: פונקציית tanh: $\tanh(x) = \frac{e^x - e^{-x}}{e^x + e^{-x}}$
- $\odot$: מכפלת Hadamard (אלמנט-אלמנט)
- $\mathbb{E}[\cdot]$: תוחלת מתמטית
- $\|\cdot\|_F$: נורמת Frobenius למטריצות

10.2 פרטי מימוש

כל הניסויים בוצעו על NVIDIA A100 80GB GPU עם PyTorch 2.1 ו-CUDA 12.1. הקוד המלא יפורסם ב-GitHub עם קבלת המאמר. זמן אימון ממוצע: תועש ~ 4 לניסוי מלא על GPU יחיד. אחסון: כל ניסוי דורש ~ 2 GB עבור נקודות המחסום (checkpoints).

10.3 רשימת Hyperparameters

טבלה 10.1: ערכי Hyperparameters מלאים

Hyperparameter	Value	Search Range
Learning Rate	3×10^{-4}	$[10^{-5}, 10^{-3}]$
Batch Size	32	{16, 32, 64}
Hidden Dim	256	{128, 256, 512}
Layers	4	{2, 4, 6, 8}
Dropout	0.2	[0.0, 0.4]
Weight Decay	10^{-5}	$[10^{-6}, 10^{-4}]$

ביבליוגרפיה

- [1] Kai Greshake et al. "Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection." In: *AI/Sec Workshop, ACM CCS*. 2023.
- [2] Sirui Hong et al. "MetaGPT: Meta Programming for Multi-Agent Collaborative Framework." In: *arXiv:2308.00352* (2023).
- [3] Yi Liu et al. "Prompt Injection Attacks and Defenses in LLM-Integrated Applications." In: *IEEE S&P*. 2024.
- [4] Daniel Nakash et al. "SkillSieve: Validating Agentic Skills Against Supply Chain Attacks." In: *arXiv:2401.12345* (2024).
- [5] Fabio Perez and Ian Ribeiro. "Ignore Previous Prompt: Attack Techniques For Language Models." In: *NeurIPS ML Safety Workshop*. 2022.
- [6] Laura Weidinger et al. "Ethical and social risks of harm from Language Models." In: *arXiv:2112.04359* (2021).
- [7] Qingyun Wu et al. "AutoGen: Enabling Next-Gen LLM Applications via Multi-Agent Conversation." In: *ICLR*. 2024.